

MASTERCAMP — CYBERSÉCURITÉ & MANAGEMENT DE PROJET

PROJET OSSI

Infrastructure de Sécurité Open Source pour PME

Livrable 1 : Rapport d'Architecture Technique

Groupe :

Kevin Ojoduma-Quere
Guillaume Ortells
Antoine Poirier
Emmanuel Rajaonera
Mohamed Ouadihi

18 juin 2026

Table des matières

1	Description de la solution envisagée	2
1.1	Vision globale et philosophie architectural	2
1.2	Périmètre réseau et segmentation	2
1.3	Interconnexion des sites et mobilité des utilisateurs	3
1.3.1	Tunnel IPSec site-à-site	3
1.3.2	VPN nomade pour les télétravailleurs	3
1.4	Analyse active du trafic et observabilité	3
1.5	Intelligence artificielle souveraine et vulgarisation des alertes	4
2	État de l’art et justification des choix technologiques	4
2.1	Positionnement général : open source souverain versus solutions propriétaires	4
2.2	Justification du pare-feu : pfSense face à ses alternatives	6
2.3	Justification du VPN nomade : WireGuard face à OpenVPN	6
2.4	Justification de l’IDS/IPS : Suricata face à Snort	7
2.5	Justification du modèle d’IA : déploiement local via Ollama face aux API cloud propriétaires	7

1 Description de la solution envisagée

1.1 Vision globale et philosophie architectural

La solution **OSSI** (*Open Source Security Infrastructure*) que nous proposons repose sur une philosophie de **défense en profondeur** (*Defense in Depth*), principe fondateur de la sécurité des systèmes d'information qui consiste à multiplier les couches de protection indépendantes afin qu'aucun point de défaillance unique ne compromette l'intégrité globale du système. Contrairement aux architectures monolithiques où la sécurité est concentrée sur un seul équipement périmétrique, l'approche retenue distribue les mécanismes de contrôle à chaque niveau de la pile réseau : filtrage stateful au niveau du pare-feu, inspection applicative au niveau de l'IDS/IPS, cloisonnement logique par la segmentation, et surveillance comportementale par la collecte centralisée des journaux.

L'ensemble des briques technologiques composant cette architecture est issu de l'écosystème **open source**, garantissant ainsi la **souveraineté numérique** de la PME concernée. Cette souveraineté se traduit concrètement par l'absence de dépendance vis-à-vis d'éditeurs propriétaires, par la maîtrise totale du code déployé, et par le maintien de l'ensemble des données sensibles au sein du périmètre de confiance de l'entreprise. La solution est dimensionnée pour couvrir trois types d'entités : un **site principal** hébergeant les serveurs et les ressources critiques, un **site isolé** dont les flux doivent être intégrés de manière sécurisée, et une population de **télétravailleurs** nécessitant un accès nomade fiable et chiffré.

1.2 Périmètre réseau et segmentation

La pierre angulaire de toute architecture sécurisée réside dans la **segmentation réseau**, qui consiste à subdiviser l'espace d'adressage en zones logiques étanches, chacune soumise à une politique de filtrage adaptée à son niveau de confiance et à la criticité des ressources qu'elle héberge. La solution OSSI articule l'infrastructure autour de quatre zones distinctes.

La **zone WAN** (*Wide Area Network*) constitue l'interface entre le système d'information de la PME et les réseaux non maîtrisés, notamment Internet. Tout flux entrant en provenance de cette zone est présumé hostile jusqu'à preuve du contraire et est soumis à un filtrage strict par le pare-feu **pSense**, qui opère comme première ligne de défense.

La **zone LAN** (*Local Area Network*) regroupe l'ensemble des postes de travail, des équipements utilisateurs et des serveurs internes. Cette zone bénéficie d'un niveau de confiance supérieur, mais reste soumise à des règles de filtrage interne afin de contenir les mouvements latéraux qui pourraient résulter d'une compromission d'un poste.

La **zone DMZ** (*Demilitarized Zone*) héberge les services exposés vers l'extérieur — serveurs web, relais de messagerie, points de terminaison VPN — qui nécessitent d'être accessibles depuis Internet tout en étant strictement isolés du LAN. Un serveur compromis en DMZ ne doit en aucun cas constituer un pivot vers le réseau interne.

La **zone VPN** regroupe les tunnels chiffrés, tant site-à-site qu'itinérants, et constitue une zone de transit contrôlée permettant d'étendre le périmètre de confiance aux entités distantes de manière maîtrisée. Les règles de filtrage appliquées à cette zone différencient explicitement les flux légitimes des connexions anormales.

Cette segmentation rigoureuse réduit mécaniquement la **surface d'attaque** de la PME en limitant la portée de toute intrusion à la zone compromise, et en rendant coûteuse toute tentative de mouvement latéral vers des zones à plus haute criticité.

1.3 Interconnexion des sites et mobilité des utilisateurs

1.3.1 Tunnel IPsec site-à-site

L'interconnexion permanente entre le site principal et le site isolé est assurée par un **tunnel IPsec** (*Internet Protocol Security*) en mode *site-à-site*. Ce protocole de sécurité opère au niveau de la couche réseau (couche 3 du modèle OSI) et garantit la **confidentialité**, l'**intégrité** et l'**authenticité** des communications inter-sites en s'appuyant sur des algorithmes de chiffrement éprouvés, comme **AES-256** pour le chiffrement des données et **SHA-256** ou **SHA-512** pour l'intégrité, ainsi que sur le protocole **IKEv2** (*Internet Key Exchange version 2*) pour la négociation automatisée des associations de sécurité.

Le tunnel IPsec est configuré en mode *always-on*, c'est-à-dire qu'il est automatiquement rétabli en cas d'interruption de la connexion WAN, assurant ainsi la robustesse et la permanence de l'interconnexion. Cette approche est nativement prise en charge par **pfSense**, qui expose une interface de configuration graphique permettant de paramétrer les politiques de phase 1 (IKE) et de phase 2 (ESP/AH) avec précision.

1.3.2 VPN nomade pour les télétravailleurs

L'accès sécurisé des télétravailleurs est assuré par **WireGuard**, un protocole VPN fondé sur des primitives cryptographiques de nouvelle génération (**ChaCha20** pour le chiffrement, **Poly1305** pour l'authentification, **Curve25519** pour l'échange de clés). WireGuard est intégré directement à pfSense sous la forme d'un module natif, simplifiant le déploiement et la gestion des pairs.

L'**authentification forte** est assurée par la combinaison d'une **infrastructure à clés publiques (PKI)** dédiée, qui permet la génération, la signature et la révocation de certificats clients, et d'un mécanisme d'**authentification à deux facteurs (2FA)** s'appuyant sur le protocole **TOTP** (*Time-based One-Time Password*). Cette combinaison garantit qu'un certificat seul, en cas de vol, ne suffit pas à établir une connexion illégitime. OpenVPN est conservé en solution de repli afin d'assurer la compatibilité avec les équipements ou les environnements réseau qui ne supportent pas WireGuard.

1.4 Analyse active du trafic et observabilité

La visibilité sur les flux traversant l'infrastructure est une condition nécessaire à toute posture de sécurité proactive. Le couplage entre la **détection et prévention d'intrusions (IDS/IPS)** et la **collecte centralisée des journaux** constitue le dispositif d'observabilité de la solution OSSI.

Suricata est déployé en mode **IPS** (*Inline Prevention System*) en coupure sur les interfaces réseau exposées du pare-feu pfSense. Il opère une inspection approfondie des paquets (**DPI** — *Deep Packet Inspection*), confrontant le trafic à des jeux de règles régulièrement mis à jour notamment les ensembles **Emerging Threats** et **Snort VRT**, afin d'identifier les signatures d'attaques connues, les comportements anormaux et les tentatives d'exploitation de vulnérabilités. En mode IPS, Suricata dispose du pouvoir de **bloquer en temps réel** les paquets identifiés comme malveillants, sans intervention humaine, réduisant ainsi drastiquement le temps de réaction face aux menaces courantes.

La **collecte et la centralisation des journaux** est assurée par un agent **syslog** configuré sur pfSense et Suricata, qui remonte l'ensemble des événements vers une instance centralisée. L'analyse corrélée de ces flux de logs permet d'identifier des schémas d'attaque distribués qui seraient imperceptibles en analysant chaque source de manière isolée, et

constitue la matière première du moteur d'**intelligence artificielle** décrit dans la section suivante.

1.5 Intelligence artificielle souveraine et vulgarisation des alertes

L'un des défis majeurs de la cybersécurité en contexte PME réside dans la **fracture sémantique** qui sépare les alertes brutes générées par les outils de sécurité de la capacité de compréhension des décideurs non techniciens. Une alerte Suricata telle que `ET SCAN Nmap Scripting Engine User-Agent Detected` ou un log pfSense mentionnant des paquets bloqués avec des flags TCP anormaux ne permet pas à un dirigeant d'entreprise d'évaluer le risque réel et d'arbitrer une réponse appropriée.

La solution OSSI intègre un **modèle de langage de grande taille** (LLM — *Large Language Model*) déployé localement via le moteur d'inférence **Ollama**. Ce LLM ingère quotidiennement les alertes brutes collectées par Suricata ainsi que les événements significatifs remontés par pfSense, et génère automatiquement un **Rapport No-Expert** : un document synthétique, rédigé en langage naturel et compréhensible sans formation technique, qui résume les incidents de la journée, leur niveau de gravité, les actions correctives déjà prises automatiquement et, le cas échéant, les points d'attention nécessitant une décision humaine.

La nature **locale** du déploiement est fondamentale : les journaux de sécurité, qui peuvent contenir des informations stratégiquement sensibles (tentatives de connexion, noms d'utilisateurs, adresses IP internes, communications métier), ne quittent **jamais** le périmètre de confiance de l'entreprise. Cette approche s'oppose radicalement à l'utilisation d'API cloud propriétaires (OpenAI, Anthropic et autres) qui impliquent nécessairement la transmission de données sensibles vers des infrastructures tierces, exposant ainsi l'entreprise à des risques de conformité au **RGPD** et à des risques d'espionnage industriel. L'IA souveraine constitue ainsi le dernier étage de la défense en profondeur, transformant la complexité technique en intelligence décisionnelle accessible.

2 État de l'art et justification des choix technologiques

2.1 Positionnement général : open source souverain versus solutions propriétaires

Le marché de la sécurité réseau pour les PME est dominé par des acteurs propriétaires dont les offres, bien que fonctionnellement complètes, imposent des modèles économiques et des contraintes de dépendance incompatibles avec les contraintes budgétaires et les exigences de souveraineté des petites et moyennes entreprises. Le tableau 1 établit une comparaison structurée entre l'approche retenue pour OSSI et les offres représentatives du marché propriétaire.

Il ressort de cette comparaison que les solutions propriétaires offrent un avantage substantiel en matière de support contractualisé, ce qui peut constituer un facteur décisif pour des entreprises dépourvues de compétences internes. Toutefois, pour une PME cherchant à maîtriser ses coûts et à préserver sa souveraineté numérique, l'approche open source, complétée par un contrat de prestation avec un intégrateur spécialisé si nécessaire, présente un rapport valeur/coût nettement supérieur.

TABLE 1 – Comparaison générale : approche open source (OSSI) vs solutions propriétaires

Critère	OSSI (Open Source)	Fortinet FortiGate	Cisco ASA / Firepower
CAPEX initial	Matériel générique uniquement ; licences logicielles nulles	Acquisition du boîtier propriétaire requise (3 000 à 20 000 € selon gamme)	Acquisition du boîtier propriétaire requise (5 000 à 30 000 € selon gamme)
OPEX annuel	Maintenance communautaire gratuite ; coût limité à l'hébergement et au temps administrateur	Abonnement FortiCare et FortiGuard obligatoire (1 500 à 8 000 €/an)	Abonnements SmartNet et Talos Intelligence obligatoires (2 000 à 10 000 €/an)
Souveraineté et contrôle des données	Total : code auditable, données confinées localement, absence de télémétrie obligatoire	Partielle : télémétrie vers les serveurs Fortinet, résidence des données non garantie en Europe	Partielle : télémétrie vers les serveurs Cisco Talos, dépendance aux infrastructures cloud américaines
Flexibilité et personnalisation	Maximale : accès au code source, écosystème de plugins utile, adaptation à toute topologie	Limitée : personnalisation contrainte par les fonctionnalités du firmware propriétaire	Limitée : personnalisation contrainte par les licences et les versions de l'IOS/ASA OS
Support et garantie	Communautaire (forums, documentation, prestataires tiers) ; pas de SLA garanti par défaut	Support constructeur avec SLA contractuel (réponse en 4h à 24h selon niveau)	Support constructeur avec SLA contractuel (TAC Cisco, 24h/24 7j/7 selon contrat)

2.2 Justification du pare-feu : pfSense face à ses alternatives

Le choix du composant pare-feu détermine en grande partie la robustesse et l'évolutivité de toute l'architecture. L'écosystème open source propose plusieurs distributions spécialisées dont les trois principales sont **pfSense**, **OPNsense** et **IPFire**.

IPFire est une distribution Linux orientée pare-feu dont la conception simple la rend accessible mais limite sa capacité à servir de socle à une architecture complexe. Son écosystème de modules additionnels (*Pakfire*) est sensiblement plus restreint que celui de ses concurrents, et sa communauté, bien qu'active, demeure de taille plus modeste. Pour un déploiement intégrant simultanément IPSec, WireGuard, Suricata et du *traffic shaping* avancé, IPFire impose une complexité de configuration manuelle supérieure sans apporter de bénéfice différenciant.

OPNsense est un fork de pfSense apparu en 2015, dont la qualité de l'interface graphique et le modèle de mises à jour plus fréquent sont généralement reconnus. Il présente toutefois un historique de déploiement en production moins étendu que pfSense, et son écosystème de plugins tiers est encore en cours de maturation sur certains points.

pfSense est retenu comme socle pare-feu de la solution OSSI pour les raisons suivantes. D'abord, sa **maturité** : développé depuis 2004 sur la base du système d'exploitation **FreeBSD**, il bénéficie d'une base d'utilisateurs et de déploiements en production considérable, d'une documentation exhaustive et d'un historique de correctifs de sécurité rigoureux. Ensuite, son **écosystème de packages** : le gestionnaire de paquets intégré propose nativement Suricata, WireGuard, OpenVPN, *ntopng*, ainsi qu'un gestionnaire de certificats PKI (**ACME**/*Let's Encrypt*) et des modules de *traffic shaping* basés sur **HFSC** et **PRIQ**. Enfin, sa **large communauté** garantit la pérennité des développements et la disponibilité de ressources d'expertise sur le marché des prestataires.

2.3 Justification du VPN nomade : WireGuard face à OpenVPN

L'accès VPN nomade impose des exigences spécifiques souvent négligées : faible latence, robustesse lors des changements de réseau (itinérance entre Wi-Fi et données mobiles), et facilité de déploiement sur des équipements hétérogènes (Windows, macOS, Android, iOS). Cette comparaison porte sur les deux solutions open source de référence que sont **WireGuard** et **OpenVPN**.

OpenVPN, créé en 2001, est la référence historique du VPN open source. Il s'appuie sur la bibliothèque **OpenSSL** et supporte une très large gamme de chiffrements et de configurations, ce qui en fait une solution universelle mais également complexe. Sa base de code dépasse 70 000 lignes, ce qui rend son audit de sécurité exhaustif particulièrement laborieux. Sur le plan des performances, OpenVPN opère en espace utilisateur, ce qui engendre une surcharge notable due aux multiples changements de contexte entre l'espace noyau et l'espace utilisateur lors du traitement de chaque paquet.

WireGuard, publié en 2016 et intégré au noyau Linux depuis la version 5.6 (mars 2020), adopte une philosophie radicalement différente. Sa base de code ne dépasse pas 4 000 lignes, facilitant considérablement l'audit de sécurité et réduisant mécaniquement la surface d'attaque cryptographique. Il s'appuie sur des **primitives cryptographiques modernes** et soigneusement choisies : **ChaCha20-Poly1305** pour le chiffrement authentifié, **Curve25519** pour l'échange de clés *Diffie-Hellman*, et **BLAKE2s** pour le hachage. L'exécution en espace noyau (*kernel space*) élimine la surcharge des changements de contexte et se traduit par des **performances brutes** nettement supérieures à OpenVPN, avec une **latence réduite** et un débit significativement plus élevé, notamment sur les

connexions mobiles. La gestion de l'**itinérance réseau** est native : WireGuard maintient le tunnel lors d'un changement d'adresse IP sans nécessiter de reconnexion, contrairement à OpenVPN qui doit renégocier la session.

WireGuard is donc privilégié comme solution principale pour les accès nomades de la solution OSSI. OpenVPN est conservé en **solution de repli** pour les environnements réseau restrictifs (réseaux d'hôtels ou d'entreprises tiers) qui bloquent le port UDP utilisé par WireGuard, OpenVPN pouvant être configuré sur le port TCP 443 pour contourner ces restrictions.

2.4 Justification de l'IDS/IPS : Suricata face à Snort

La détection et la prévention d'intrusions constituent le mécanisme d'analyse active le plus exigeant en termes de ressources de traitement, puisqu'elles nécessitent l'inspection en temps réel de l'intégralité des paquets traversant les interfaces surveillées. Le comparatif porte ici sur les deux moteurs open source historiques : **Suricata** et **Snort**.

Snort, créé par Sourcefire en 1998 et aujourd'hui maintenu par **Cisco Talos**, est le pionnier des IDS open source. Son modèle d'exécution repose sur un **architecture monothreadée** : un seul fil d'exécution traite l'ensemble des paquets capturés, ce qui constituait une conception adaptée aux débits réseau des années 2000, mais qui représente aujourd'hui un **goulot d'étranglement** structurel face aux infrastructures 10 Gbps et au-delà. Si Snort 3 (publié en 2021) introduit des améliorations significatives, y compris un support limité du multithreading, son architecture native reste fondamentalement différente de celle de Suricata.

Suricata, développé par l'**OISF** (*Open Information Security Foundation*) depuis 2009, a été conçu dès l'origine avec une **architecture multithreadée native**. L'ensemble des opérations (capture des paquets, décodage, détection de signatures, journalisation) est distribué sur l'ensemble des cœurs processeur disponibles, permettant une mise à l'échelle quasi linéaire des performances avec le nombre de cœurs. Cette conception le rend intrinsèquement supérieur à Snort pour le traitement des **flux à haut débit** typiques des infrastructures réseau modernes.

Par ailleurs, Suricata supporte nativement des fonctionnalités avancées indispensables à la solution OSSI : l'**inspection TLS/SSL** (analyse des métadonnées des flux chiffrés sans déchiffrement), la **détection de protocoles applicatifs** par inspection comportementale (*protocol detection*), la **journalisation structurée en JSON** via le format **EVE** (*Extensible Event Format*) qui facilite l'intégration avec des outils d'analyse aval, ainsi qu'une compatibilité totale avec les jeux de règles **Snort VRT** et **Emerging Threats Open**, assurant la portabilité des politiques de détection existantes.

Suricata est donc retenu comme moteur IDS/IPS de la solution OSSI, en s'appuyant sur les jeux de règles **Emerging Threats** maintenus par **Proofpoint**, régulièrement mis à jour et couvrant les menaces les plus récentes.

2.5 Justification du modèle d'IA : déploiement local via Ollama face aux API cloud propriétaires

L'intégration de l'intelligence artificielle générative dans une chaîne de traitement de données de sécurité soulève une question architecturale fondamentale : le modèle doit-il être hébergé localement ou interrogé via une **API cloud** propriétaire ? L'analyse comparative présentée ici oppose le déploiement local via **Ollama** aux services d'API offerts

par les principaux acteurs du marché, notamment **OpenAI GPT-4** et les offres cloud de fournisseurs tiers.

L'utilisation d'une API cloud propriétaire présente l'avantage d'accéder à des modèles de très grande taille (*frontier models*) sans infrastructure dédiée. Cependant, cette approche est structurellement incompatible avec le contexte de la sécurité réseau pour plusieurs raisons fondamentales.

Premièrement, la **confidentialité des données** : les journaux générés par Suricata et pfSense contiennent des informations hautement sensibles : adresses IP internes, noms de domaines accédés, comptes utilisateurs impliqués dans des événements de sécurité, topologie interne du réseau. L'envoi de ces données vers des serveurs tiers situés hors du périmètre de l'entreprise, *a fortiori* vers des infrastructures hébergées en dehors de l'Union Européenne, constitue une **violation potentielle du Règlement Général sur la Protection des Données (RGPD)**, notamment au regard de l'article 46 relatif aux transferts de données vers des pays tiers et de l'article 32 relatif à la sécurité du traitement. Le risque de **fuite de données sensibles** vers des tiers non contrôlés est donc structurel et non mitigable dans ce modèle.

Deuxièmement, le **coût opérationnel** : les API cloud propriétaires facturent à l'usage, indexé sur le volume de tokens traités. Dans un contexte de journalisation continue où plusieurs milliers d'événements sont générés quotidiennement, les coûts d'inférence peuvent atteindre des montants significatifs à l'échelle d'un déploiement annuel.

Troisièmement, la **dépendance** : toute interruption du service API cloud entraîne l'indisponibilité complète de la fonctionnalité de rapport automatisé, sans recours possible.

Ollama est un moteur d'inférence local qui permet d'exécuter des modèles de langage optimisés (famille **Llama 3**, **Mistral**, **Qwen2** et autres) sur du matériel générique, y compris sans **GPU** dédié pour des modèles quantifiés de taille modeste (7B à 13B de paramètres). Déployé sur un serveur hébergé dans les locaux de la PME ou dans son environnement virtualisé privé, il garantit que **l'ensemble du cycle de traitement** (Ingestion des logs, inférence, génération du rapport) s'effectue exclusivement au sein du périmètre de confiance de l'entreprise. La gratuité opérationnelle (modèles open source, infrastructure existante) et l'indépendance vis-à-vis de tout prestataire externe complètent les arguments en faveur de cette approche.

L'IA souveraine via Ollama est donc retenue comme composant intégral de la solution OSSI, tant pour des raisons de conformité réglementaire que pour ses avantages en matière de coût, de résilience et de souveraineté des données.